RIASSUNTO REPORT 2025 DBIR
DATA BREANCH INVESTIGATIONS

Un attacco ransomware realistico contro un'azienda di medie dimensioni segue una sequenza strutturata e progressiva, simile a quella utilizzata dai gruppi APT (Advanced Persistent Threat). L'obiettivo principale dell'attaccante non è immediatamente la cifratura dei file, ma il controllo completo dell'infrastruttura, l'esfiltrazione dei dati e solo infine l'estorsione economica.

La prima fase è la ricognizione (Reconnaissance), durante la quale l'attaccante raccoglie informazioni sull'azienda tramite fonti pubbliche (OSINT), identifica dipendenti, email e sistemi esposti come VPN, RDP o server web. Gli indicatori di compromissione includono scansioni ripetute delle porte e tentativi di connessione sospetti provenienti da IP esterni.

Segue la fase di accesso iniziale (Initial Access), ottenuto tipicamente tramite phishing o utilizzo di credenziali rubate. In questa fase l'attaccante entra per la prima volta nella rete aziendale. Indicatori tipici sono login da paesi insoliti o l'esecuzione anomala di processi come PowerShell avviato da applicazioni Office.

Una volta entrato, l'attaccante esegue malware (Execution) per stabilire una comunicazione con un server di comando e controllo (C2). Questo malware consente di scaricare ulteriori strumenti malevoli. Gli indicatori includono connessioni sospette verso IP sconosciuti e processi anomali in esecuzione.

Successivamente viene stabilita la persistenza (Persistence), per garantire l'accesso continuo anche dopo riavvii o cambiamenti di sistema. Ciò avviene tramite la creazione di servizi nascosti, chiavi di registro o task schedulati sospetti.

Nella fase di escalation dei privilegi (Privilege Escalation), l'attaccante ottiene privilegi amministrativi, spesso tramite il furto di credenziali dalla memoria del sistema. Indicatori includono accessi sospetti a processi critici come LSASS e assegnazione anomala di privilegi amministrativi.

Segue il movimento laterale (Lateral Movement), durante il quale l'attaccante si diffonde ad altri sistemi della rete, inclusi server critici e controller di dominio. Indicatori includono accessi simultanei a più sistemi e connessioni SMB sospette.

La fase di discovery consente all'attaccante di identificare dati sensibili, backup e sistemi critici, utilizzando comandi per enumerare utenti, gruppi e sistemi presenti nella rete.

Successivamente l'attaccante disabilita i sistemi di difesa (Defense Evasion), come antivirus e sistemi di backup, per impedire il rilevamento e il recupero.

Prima della cifratura, avviene spesso l'esfiltrazione dei dati (Data Exfiltration), che consente all'attaccante di rubare informazioni sensibili da utilizzare come ulteriore leva di ricatto.

Infine, viene distribuito il ransomware (Impact), che cifra i file e rende i sistemi inutilizzabili, lasciando una richiesta di riscatto. Gli indicatori includono file rinominati, creazione di note di riscatto e uso anomalo delle risorse di sistema.

Secondo il Verizon Data Breach Investigations Report, il ransomware è presente nel 44% delle violazioni analizzate e spesso viene preceduto da furto di credenziali, sfruttamento di vulnerabilità e movimento laterale nella rete
2025-dbir-data-breach-investiga…
.
Per difendersi, un'azienda deve implementare misure come autenticazione multifattore (MFA), monitoraggio continuo con sistemi EDR, segmentazione della rete, backup offline, gestione delle vulnerabilità e sistemi di logging centralizzati (SIEM). Queste misure consentono di rilevare e bloccare l'attacco nelle fasi iniziali, prima che venga distribuito il ransomware.
In sintesi, il ransomware è solo la fase finale di un attacco complesso e strutturato. La vera difesa consiste nel rilevare e interrompere l'attacco nelle fasi precedenti, quando l'attaccante sta ancora tentando di ottenere accesso e controllo della rete.

RICHIESTA INFORMAZIONI

PROMPT: *forniscimi tutte le informazioni relative a phishing e social engineering: statistiche chiave, tecniche di attacco più diffuse, nuove tendenze emerse quest'anno, dati sulle motivazioni degli attaccanti e consigli difensivi contenuti nel report. Organizza la risposta in sezioni chiare.*

1. Statistiche chiave su phishing e social engineering

Coinvolgimento del fattore umano

- Il **60% delle violazioni coinvolge direttamente il fattore umano**, inclusi phishing, errori e abuso di credenziali.

2025-dbir-data-breach-investiga…

- Questo conferma che l'essere umano resta uno dei principali vettori di compromissione.

Phishing come vettore iniziale

- Il phishing rappresenta circa il **15% dei vettori di accesso iniziale**, rimanendo una delle principali tecniche di compromissione.

2025-dbir-data-breach-investiga…

- Anche quando non è il vettore iniziale diretto, spesso è la causa primaria del furto di credenziali utilizzate successivamente.

Relazione con credential abuse

- Il **22% delle violazioni coinvolge credenziali rubate**, spesso ottenute tramite phishing o social engineering.

2025-dbir-data-breach-investiga…

- Inoltre, il **54% delle vittime ransomware aveva credenziali compromesse presenti in dump di infostealer**, indicando una forte correlazione tra phishing e attacchi ransomware.

2025-dbir-data-breach-investiga…

Uso crescente dell'AI nel phishing

- La percentuale di email malevole generate o assistite da AI è **raddoppiata negli ultimi due anni**, passando da circa 5% a 10%.

2025-dbir-data-breach-investiga…

---

2. Tecniche di phishing e social engineering più diffuse

2.1 Phishing via email (tecnica principale)

Caratteristiche:

- Email con allegati malevoli
- Link a siti fake
- Falsificazione di identità aziendali

Obiettivo:

- Rubare credenziali
- Installare malware
- Ottenere accesso iniziale

Indicatori tipici:

- Email con domini simili ma falsi
- Link a siti clone
- Allegati Office con macro

2.2 Credential harvesting (furto credenziali)

Metodo:

- Pagina fake che imita login aziendale
- Utente inserisce username/password

Conseguenze:

- Accesso diretto a VPN
- Accesso a email aziendale
- Accesso a infrastruttura cloud

2.3 Pretexting

Tecnica:

- Attaccante finge di essere:
  - IT support
  - manager
  - fornitore

Obiettivo:

- Convincere la vittima a fornire accesso o informazioni

2.4 Malware delivery via social engineering

L'utente viene convinto a:

- aprire allegato
- installare software
- eseguire file

Risultato:

- installazione malware
- creazione backdoor

---

3. Nuove tendenze emergenti

3.1 Uso crescente dell'AI per phishing

Gli attaccanti usano AI per:

- scrivere email realistiche

- eliminare errori grammaticali
- simulare comunicazioni aziendali

Risultato:

- phishing più credibile
- maggiore successo degli attacchi

3.2 Infostealer malware come supporto al phishing

Infostealer raccolgono:

- credenziali browser
- cookie di sessione
- access token

Dati chiave:

- Il 46% dei sistemi compromessi contenenti credenziali aziendali erano dispositivi non gestiti.

2025-dbir-data-breach-investiga…

Questo indica forte esposizione tramite dispositivi personali.

3.3 Uso combinato phishing + ransomware

Sequenza tipica:

1. phishing
2. furto credenziali
3. accesso rete
4. movimento laterale
5. ransomware

3.4 Uso di piattaforme GenAI da parte dei dipendenti

- Il 15% dei dipendenti utilizza sistemi AI con dispositivi aziendali.

2025-dbir-data-breach-investiga…

Rischio:

- esposizione dati aziendali
- possibile leakage informazioni

---

4. Motivazioni degli attaccanti

Motivazione principale: finanziaria

- Il **motivo principale degli attacchi è finanziario (89%)**.

2025-dbir-data-breach-investiga…

Obiettivi:

- ransomware
- furto dati

- estorsione

Motivazione secondaria: espionage

- Il 17% delle violazioni ha motivazione di spionaggio.

2025-dbir-data-breach-investiga…

Obiettivo:

- accesso a informazioni sensibili
- accesso a infrastrutture critiche

Uso di access brokers

Access brokers:

- vendono credenziali rubate
- vendono accesso a reti aziendali

Fonte principale:

- phishing
- infostealer

---

5. Target principali

I più colpiti:

- dipendenti normali (end users)
- utenti con accesso VPN
- utenti con accesso email aziendale

Perché:

- meno protetti
- più facili da manipolare

---

6. Indicatori di compromissione (IoC)

Indicatori phishing:

- login da posizione geografica anomala
- accesso fuori orario lavorativo
- accessi multipli falliti

Indicatori endpoint:

- Office che avvia PowerShell
- esecuzione file sconosciuti

Indicatori network:

- connessioni verso IP sospetti
- traffico verso C2

---

7. Impatto operativo

Phishing può causare:

- accesso completo alla rete
- furto dati
- ransomware
- downtime operativo
- perdita finanziaria

Il phishing è spesso il primo passo di attacchi ransomware.

---

8. Contromisure difensive raccomandate nel report

8.1 Implementare MFA (controllo più importante)

Blocca:

- uso credenziali rubate

Protezione contro:

- credential abuse
- accesso VPN non autorizzato

8.2 Security awareness training

Addestrare utenti a:

- riconoscere phishing
- non aprire allegati sospetti
- verificare email sospette

8.3 Email filtering avanzato

Blocca:

- email malevole
- link sospetti

8.4 Monitoraggio accessi

Monitorare:

- login sospetti
- accessi da paesi anomali

8.5 Endpoint Detection and Response (EDR)

Rileva:

- malware
- attività sospette

8.6 Least privilege principle

Limitare accessi utenti:

- riduce impatto compromissione

8.7 Monitoraggio credenziali compromesse

Verificare:

- credential dumps
- leak database

---

9. Conclusione (sintesi operativa)

Il phishing e il social engineering rappresentano una delle principali minacce alla sicurezza aziendale e sono coinvolti indirettamente o direttamente nella maggioranza delle violazioni.

Punti chiave:

- 60% delle violazioni coinvolge il fattore umano
- 15% usa phishing come accesso iniziale
- 22% usa credenziali rubate
- phishing spesso porta a ransomware
- AI sta rendendo il phishing più efficace

Il phishing è il punto di ingresso più comune per attacchi complessi.